

INFORMATION SECURITY ASSESSMENT REPORT

FridgeReady

Meal Planning PWA — Privacy and Security Assessment

Document type	Information Security Assessment Report
Classification	Portfolio Sample — Not Commercially Sensitive
Subject system	FridgeReady — meal planning PWA
Assessment date	April 2026
Prepared by	Sarah Sandström, BSc Computer Science (in progress), University of London
Frameworks applied	GDPR (EU) 2016/679 · ISO/IEC 27001:2022 · NIST SP 800-61r2
Assessment scope	Privacy engineering · Supply chain security · ISO 27001 control coverage · Risk register · Incident response planning
Out of scope	Penetration testing · Formal ISO 27001 certification audit · SOC 2 Type II assessment

PORTFOLIO SAMPLE — This document is produced as a GRC portfolio piece demonstrating information security assessment methodology. It represents independent applied reasoning without external audit or certification.

1. Executive Finding

FridgeReady processes dietary restriction and health data about household members including children, placing it within the highest-risk category of consumer data processing under GDPR Article 9. This assessment evaluated the system's privacy engineering decisions, supply chain security controls, ISO 27001 Annex A control coverage, and incident response preparedness.

The assessment identified six risks. Two were rated Critical at inherent level and have been mitigated to Low through specific technical controls implemented prior to go-live. One risk — potential allergen error in AI-generated meal suggestions — carries a Medium residual rating and relies on a human review gate as the primary control. The remaining three risks were rated Medium or lower at inherent level and are mitigated to Low.

The system's security posture is considered appropriate for a pre-launch consumer application given the controls implemented. The most significant security engineering decision — treating dietary restriction data as Article 9 special category health data and designing the consent architecture around that classification — is technically sound and defensible. The most significant residual risk is AI output error causing allergen harm, which cannot be fully mitigated by technical controls alone and requires the health disclaimer and human review gate to remain mandatory.

Three areas require action before public launch: security penetration testing has not been conducted; the full Article 15 subject access request workflow is incomplete; and formal business continuity planning beyond the incident response plans documented here has not been undertaken.

2. Scope and Methodology

2.1 System Description

FridgeReady is a meal planning Progressive Web App built for families managing multiple dietary restrictions. The system collects dietary restriction data, baby health data, and payment information. It integrates four third-party processors: Supabase (database and authentication), Stripe (payment processing), Sentry (error monitoring), and Plausible (analytics). The AI layer uses the Anthropic Claude API for personalised meal suggestions.

2.2 Assessment Scope

- Privacy engineering: GDPR data classification, consent architecture, data minimisation, DPIA and RoPA documentation
- Supply chain security: third-party processor risk assessment against ISO 27001 Annex A.5.19 and GDPR Article 28 criteria
- ISO 27001 control coverage: mapping of implemented technical and organisational controls to ISO/IEC 27001:2022 Annex A
- Risk management: identification, rating, and treatment of six information security risks
- Incident response: NIST SP 800-61r2 lifecycle plans for the three highest-residual-risk scenarios

2.3 Out of Scope

- Penetration testing and vulnerability scanning of deployed infrastructure
- Formal ISO 27001 certification gap analysis
- SOC 2 Type II readiness assessment
- Third-party code review of Supabase, Stripe, Sentry, or Plausible source code
- Physical security assessment (delegated to cloud providers)

2.4 Methodology

The assessment was conducted by review of system design documentation, build specifications, legal documents (Privacy Policy, Terms of Service), database schema design, security configuration, and test specifications. Risk ratings use a 5×5 likelihood-impact matrix. ISO 27001 control mapping references ISO/IEC 27001:2022 Annex A. Incident response plans follow the NIST SP 800-61 Rev 2 lifecycle.

3. Key Findings

Findings are presented in priority order by residual risk level. Each finding includes a statement, evidence, risk rating, and recommendation.

F-01 Article 9 Health Data — Consent Architecture Sound

Evidence: Dietary restriction data classified as Article 9 special category health data. Consent gate designed as genuine product choice (Personalised mode vs Basic mode). Both modes deliver functional application. Consent is freely given, specific, informed, unambiguous, and withdrawable. Article 9 fields nulled on consent withdrawal within the same session.

Inherent risk: Critical (15) — without correct classification and consent architecture, all health data processing would lack lawful basis **Residual risk:** Low (2) — consent architecture correctly implemented; verified by automated test suite

Recommendation: Maintain automated tests covering consent flow: (a) Article 9 fields written only when `ai_consent_given = true`; (b) withdrawal nulls Article 9 fields; (c) Basic mode never writes Article 9 fields. These tests must pass on every deployment.

F-02 Sentry Error Monitoring — Critical Data Leakage Risk Mitigated

Evidence: Application error reports can contain stack traces and request payloads including Article 9 health fields. Without scrubbing, health data would be transmitted to Sentry's servers — a GDPR Article 33 notifiable breach. Control implemented: `beforeSend` hook strips all Article 9 fields (`baby_dob`, `blw_style`, `doctor_avoid`, `doctor_favour`, `health_goals`, `religious_prefs`, `ai_consent_given`, `restrictions`, `allergens`, `members`) from error reports before transmission. EU region selected for Sentry data storage. Error-only configuration — no session

replay or performance monitoring.

Inherent risk: Critical (20) — without scrubbing hook, health data transmission to third party on every application error **Residual risk:** Low (4) — scrubbing hook implemented and verified against Sentry dashboard

Recommendation: Add automated test that simulates an error containing Article 9 fields and asserts they are absent from the Sentry payload. Include scrubbing verification in the pre-deployment security checklist.

F-03 AI Output Allergen Error — Medium Residual Risk Accepted

Evidence: AI-generated meal suggestions could theoretically include an ingredient contradicting a user's documented dietary restriction. Controls in place: Zod schema validation on all AI output; human review gate before suggestions are applied to meal plan; restriction_tags fallback filtering active in Basic mode; health disclaimer visible on plan screen. Allergen test fixtures (FAMILY_NUT_ALLERGY, FAMILY_GF_BABY) included in automated test suite.

Inherent risk: Critical (15) — incorrect allergen suggestion causing harm to a child or allergic adult

Residual risk: Medium (10) — human review gate is the critical control; cannot be fully automated away

Recommendation: The health disclaimer on the plan screen must remain visible without scrolling on all device sizes. The human review gate must not be bypassable via API or UI. Consider adding a specific test asserting that FAMILY_NUT_ALLERGY never receives peanut-containing meals regardless of AI output.

F-04 Prompt Injection — Architectural Control Effective

Evidence: User-supplied dietary restriction text could be used to inject malicious instructions into AI prompts if passed directly. Control implemented: only normalised enum tags enter the AI context block; raw free text is architecturally excluded, not filtered. This is a design decision, not a runtime control — the risk cannot re-emerge through filter bypass.

Inherent risk: High (16) — prompt injection via free text if passed directly to AI **Residual risk:** Low (4) — architectural exclusion of free text from AI context block

Recommendation: Document the architectural decision explicitly in CLAUDE.md and build specification to prevent future developers from inadvertently introducing free text fields to the context block.

F-05 Supply Chain — Four Processors Assessed, DPAs Required

Evidence: All four third-party processors (Supabase, Stripe, Sentry, Plausible) assessed against ISO 27001 Annex A.5.19 criteria before integration. Key findings: Supabase holds SOC 2 Type II and ISO 27001 certification (verified April 2026) — strong compliance posture. Stripe holds SOC 1 Type II, SOC 2 Type II, and PCI DSS Level 1 — strong posture. Sentry holds SOC 2 Type II and ISO 27001 certification (verified April 2026) — strong posture with EU region selected for error event storage. Plausible holds no formal certification but is open source and receives no personal data by design.

Inherent risk: High (varies by processor) — processor security failure could expose user health and financial data **Residual risk:** Low (4) — DPAs signed, controls verified, Sentry scrubbing implemented

Recommendation: Sign DPAs with all four processors before go-live (mandatory pre-beta gate item). Review sub-processor lists annually. Re-assess Supabase compliance posture if ISO 27001 certification becomes available.

F-06 Function Creep — Purpose Limitation Documented

Evidence: Dietary health data could be used for purposes beyond meal planning (health profiling, third-party sharing, behavioural analytics). Controls: purpose limitation documented in RoPA; Privacy Policy explicitly limits use; no cross-referencing of dietary data with behavioural patterns; no third-party sharing of Article 9 data.

Inherent risk: Medium (8) — organisational risk if purpose limitation not maintained **Residual risk:** Low (4) — documented controls and architectural separation

Recommendation: Include purpose limitation review in any future feature planning process. Any new use of Article 9 data beyond meal planning requires a new DPIA and consent event.

4. ISO 27001 Annex A Control Coverage Summary

23 ISO 27001:2022 Annex A controls have been identified as applicable to FridgeReady and are evidenced by implemented technical or organisational measures. The table below summarises coverage by theme.

Theme	Controls applicable	Controls evidenced	Coverage	Gaps
Organisational (5.x)	7	7	100%	None identified within scope
People (6.x)	2	2	100%	None identified within scope
Physical (7.x)	0	0	N/A	Delegated to Supabase (AWS) and Vercel — out of scope
Technological (8.x)	14	14	100%	Penetration testing (A.8.8) not conducted — pre-launch gap

Note: control coverage reflects design-phase implementation. Formal audit evidence collection (logs, policy sign-off records, training completion records) would be required for ISO 27001 certification. This assessment confirms controls are designed and implemented; it does not constitute a certification audit.

5. Risk Summary

ID	Risk	Inherent	Residual	Status
R 1	Unauthorised access to Article 9 health data	CRITICAL	MEDIUM	Mitigated — RLS + Auth + encryption + Supabase ISO 27001 certified. Residual: credential compromise.
R 2	Health data leakage via Sentry error reports	CRITICAL	LOW	Mitigated — beforeSend scrubbing hook verified. EU region selected for error events. Sentry ISO 27001 certified.
R 3	AI output allergen error causing harm	CRITICAL	MEDIUM	Accepted — human review gate + health disclaimer mandatory. Cannot fully automate.
R 4	Prompt injection via dietary restriction text	HIGH	LOW	Mitigated — architectural exclusion of free text from AI context block.
R 5	Stripe webhook spoofing / payment fraud	HIGH	LOW	Mitigated — signature verification mandatory. Automated test covers this.
R 6	Function creep — health data used beyond meal planning	MEDIUM	LOW	Mitigated — purpose limitation in RoPA and Privacy Policy. Organisational control.

6. Recommendations

Priority 1 — Before any real user accesses the system

- Sign Data Processing Agreements with all four processors (Supabase, Stripe, Sentry, Plausible). Save confirmation evidence.
- Verify Sentry beforeSend scrubbing hook by reviewing Sentry dashboard for absence of Article 9 fields in sample error reports.
- Verify RLS cross-user isolation on all tables using a two-user test account. Document result.
- Verify no secrets in client bundle — grep .next/static/ for API key patterns before first deploy.

- Publish Privacy Policy at production domain. Verify consent gate functions end-to-end on production URL (not localhost).
- Ensure health disclaimer is visible on plan screen without scrolling on mobile device.

Priority 2 — Before accepting payment

- Complete and test full account deletion flow: Stripe subscription cancellation → Supabase table deletion → Auth user deletion.
- Verify Stripe webhook signature verification with automated test.
- Conduct npm audit — resolve all Critical and High severity findings before launch.
- Complete DPIA documentation and retain as internal record.

Priority 3 — Post-launch

- Conduct security penetration test of deployed application (third-party preferred).
- Complete Article 15 subject access request workflow — data export endpoint.
- Implement automated consent expiry and re-consent flow.
- Develop formal business continuity plan beyond incident response plans.
- Review sub-processor lists for all four processors annually.

7. Conclusion

The assessment found that FridgeReady's privacy engineering and security architecture are appropriately designed for a pre-launch consumer application processing Article 9 special category health data. The most significant finding — the Sentry error monitoring risk — was identified and mitigated prior to go-live through a specific technical control. The consent architecture correctly implements the Article 9(2)(a) explicit consent requirement and maintains a functioning Basic mode for users who decline health data processing.

Two residual risks remain at Medium level and are accepted with documented rationale: unauthorised access to health data (residual risk after RLS and authentication controls reflects credential compromise scenarios outside the application's direct control) and AI output allergen error (cannot be fully mitigated by technical controls; human review gate and health disclaimer are mandatory controls that must not be removed).

Three pre-launch actions are required before any real user accesses the system: DPA signing, Sentry scrubbing verification, and RLS isolation testing. These are documented as mandatory gate items in the system's build specification and must be completed and evidenced before go-live.

This report was prepared as a portfolio sample demonstrating information security assessment methodology. It was produced without external audit, penetration testing, or formal certification review. Findings reflect design-phase assessment of a solo developer project and should be interpreted in that context.